TLP:AMBER Restricted to the recipient’s organization and its trusted clients/contractors on a need-to-know basis.

CYBER THREAT INTELLIGENCE REPORT

OpenSSH "SSHole" bypass attempted within hours of disclosure; root gained on a honeypot

From **Cybersecurity Briefing** · 2026-11-02 to 2026-11-07 · Briefing generated 2026-11-07

REPORT ID	VERSION	HANDLING	BRIEFING SECTION
CTI-20261110-03	1.0 · 2026-11-10 07:37 EST	TLP:AMBER	United States
ORIGINAL PUBLISHED	**LAST UPDATE**	**CVES**	**ANALYST**
2026-11-05	2026-11-10	CVE-2026-123158 (CVSS 8.1)	Nick Sturgeon

VULNERABILITY | HIGH | ACTIVELY EXPLOITED | OVERALL CONFIDENCE: HIGH

BOTTOM LINE UP FRONT

CVE-2026-123158, nicknamed "SSHole", is an authentication bypass reachable through the OpenSSH server (sshd) on Linux systems that use the musl C library and do not check passwords through PAM. Alpine Linux's default openssh-server package fits that profile; OpenWrt, Buildroot and Yocto builds are also named as musl platforms at risk [S2] [S3] [S5]. An unauthenticated attacker who can reach the SSH port sends a password of 257 to 1,024 bytes for an account whose password field is "*" (a key-only or password-disabled account). musl's crypt() fails on the oversized input and returns "*", sshd compares that with the stored "*", and the login succeeds in a single attempt [S5] [S12]. OpenSSH 10.6p2, released 2026-11-05, works around the problem, and Alpine shipped fixed packages for every branch from 3.16 to edge the same day [S5] [S6]. glibc distributions (Debian, Ubuntu, Fedora, RHEL family), PAM-based setups, Dropbear and OpenBSD are not affected [S1] [S11] [S12].

Exploitation is confirmed by more than one sensor network. Previdian reported its first attempt less than nine hours after the CVE was published and a successful root login on an Alpine honeypot from 89.116.89[.]18, with only id, uname and hostname run afterwards; by 2026-11-08 it counted 20 attempts from 13 addresses in nine countries [S1] [S4] [S11]. GreyNoise independently tagged the same address on 2026-11-06 and, since 2026-11-07, has recorded 20 confirmed post-exploitation chains from six attacker addresses against its own sensors [S9]. That activity goes well beyond a login check: attackers used passwordless doas to become root, read /etc/shadow, queried cloud metadata services,

added their own SSH keys (comments "SSHHOLE-HIT" and "fleet-access") for the alpine and root users, and on at least two hosts installed a Python implant called "TAC Agent" that beacons to tac.vpnla[.]org and persists as an OpenRC service [S9]. SANS ISC saw long-password login attempts on its honeypots peak at 713 on 2026-11-06 [S10]. CISA added the CVE to the Known Exploited Vulnerabilities catalog on 2026-11-09 with a due date of 2026-11-12 [S8].

The exposed population is narrow but easy to overlook. All of the following must be true: sshd on musl without PAM, password authentication enabled (the OpenSSH default), a target account with "*" in the password field, and at least one other local account with a SHA-256 or SHA-512 crypt hash [S5]. Official Alpine cloud images from 3.18.11 through 3.24.3 carry an "alpine" user with a "*" password and passwordless doas, so a successful login on those images is effectively root [S5]. Instances configured through cloud-init are protected because it turns password authentication off [S5]. What is not known: how many internet-facing hosts actually meet all the conditions, who operates the TAC Agent cluster, and whether any production victim (as opposed to a honeypot) has been compromised. watchTowr is reported to have seen only botnets and crypto miners so far [S4] [S13].

Action: find every musl-based host, container or appliance that runs sshd; upgrade to OpenSSH 10.6p2 or the distribution's fixed package and restart sshd (the upgrade alone leaves the old daemon running); where that cannot be done today, set PasswordAuthentication no and restart. On any exposed host, search /var/log/messages for "Accepted password for" lines naming alpine, root or key-only accounts, check authorized_keys for unknown keys, and look for the TAC Agent files and service. If a successful login cannot be ruled out, treat the host and every credential on it as compromised [S5] [S9].

Key judgments

ALMOST CERTAIN · HIGH CONFIDENCE
Opportunistic exploitation of internet-facing Alpine and other musl-based SSH servers will almost certainly continue and broaden over the next two weeks, because the attack needs one connection, public exploit code exists, and SSH brute-force tooling is already sending oversized passwords. [S5] [S9] [S10] [S4]

LIKELY · MODERATE CONFIDENCE
Activity will likely shift from login verification and coin mining toward durable access (planted SSH keys, implants, credential and cloud-metadata theft), as the GreyNoise TAC Agent intrusions already show; some actors will likely sell or reuse that access. [S9] [S4] [S13]

LIKELY · HIGH CONFIDENCE
Patching alone will likely leave some organizations compromised, because attackers add their own authorized_keys entries that survive the OpenSSH upgrade and a switch to key-only authentication. [S9] [S5]

> **UNLIKELY · HIGH CONFIDENCE**
> It is unlikely that mainstream enterprise server fleets built on glibc distributions with PAM are exposed; the realistic exposure sits in Alpine virtual machines and cloud images, containers that run sshd, and embedded or network devices built on OpenWrt, Buildroot or Yocto with full OpenSSH instead of Dropbear. [S5] [S6] [S12] [S2]

> **ROUGHLY EVEN CHANCE · LOW CONFIDENCE**
> There is a roughly even chance that vendors of embedded and appliance products built on musl will issue their own advisories or firmware updates in the coming weeks; those devices will stay vulnerable longer than Alpine hosts because fixes depend on vendor firmware cycles. [S2] [S3] [S8]

INDICATORS OF COMPROMISE

Network and host indicators come mainly from the GreyNoise event page for this CVE (last updated 2026-11-10 12:10 UTC) and reflect intrusions on GreyNoise sensors between 2026-11-07 and 2026-11-10; the Previdian address was published 2026-11-06 and is corroborated by a GreyNoise tag. SANS ISC addresses are sources of long-password attempts on honeypots, not confirmed compromises. Addresses in cloud and residential ranges rotate quickly, so treat IPs as short-lived; the SSH keys, file paths, hashes and C2 domain are the durable indicators. GreyNoise also lists 579 Paramiko-tagged scanner addresses, further hashes of modified system files and one partly redacted 103.x address that are not reproduced here.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
ipv4	`89[.]116[.]89[.]18`	Previdian: source of eight attempts and a confirmed root login on an Alpine honeypot; ran id, uname, hostname. GreyNoise tagged the same address for CVE-2026-123158 bypass attempts (AS51847, Japan), first hit 2026-11-06 03:53 UTC.	REPORTED	2026-11-06	[S1] [S11] [S9]
ipv4	`183[.]220[.]91[.]15`	GreyNoise confirmed exploitation and post-exploitation (China Mobile, AS9808); active 2026-11-07 01:30 to 06:11 UTC.	REPORTED	2026-11-07	[S9]
ipv4	`20[.]255[.]63[.]133`	GreyNoise confirmed exploitation (Microsoft AS8075, Hong Kong); linked to the TAC Agent deployment on victim 1.	REPORTED	2026-11-07	[S9]
ipv4	`209[.]248[.]50[.]17`	GreyNoise confirmed exploitation (AS32135, Singapore); linked to the tac-agent OpenRC service on victim 2.	REPORTED	2026-11-07	[S9]
ipv4	`79[.]116[.]138[.]30`	GreyNoise confirmed exploitation (Digi Spain, AS57269); active 2026-11-07 through 2026-11-10 against victims 3 and 4.	REPORTED	2026-11-07	[S9]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
ipv4	`20[.]2[.]81[.]241`	GreyNoise confirmed exploitation (Microsoft AS8075, Hong Kong).	REPORTED	2026-11-08	[S9]
ipv4	`47[.]80[.]65[.]43`	GreyNoise confirmed exploitation (Alibaba AS45102, Philippines).	REPORTED	2026-11-08	[S9]
ipv4	`202[.]155[.]94[.]33`	GreyNoise GT10 cluster member and block candidate tagged as exploit attempt.	REPORTED	2026-11-08	[S9]
ipv4	`152[.]175[.]65[.]88`	Listed by GreyNoise in the GT10 cluster; no first-seen date given.	REPORTED		[S9]
ipv4	`43[.]224[.]227[.]158`	GreyNoise: tagged CVE-2026-123158 bypass attempt (AS400619, Hong Kong), first hit 2026-11-05 18:34 UTC. Attempt only; success not confirmed.	REPORTED	2026-11-05	[S9]
ipv4	`213[.]86[.]169[.]133`	GreyNoise bypass-attempt tag (COLT AS8220, UK), first hit 2026-11-05; also the top source of long-password attempts on SANS ISC honeypots (48). Attempt only.	REPORTED	2026-11-05	[S9] [S10]
ipv4	`31[.]59[.]220[.]26`	GreyNoise bypass-attempt tag (AS198189, Netherlands). Attempt only.	REPORTED	2026-11-06	[S9]
ipv4	`104[.]21[.]88[.]83`	Cloudflare address the attacker pinned to tac.vpnla.org in /etc/hosts on a victim. Shared Cloudflare infrastructure: do not block by IP alone; use as a hunt pivot with the hostname.	REPORTED	2026-11-07	[S9]
domain	`tac[.]vpnla[.]org`	Command-and-control host for the TAC Agent implant (a Cloudflare Worker).	REPORTED	2026-11-07	[S9]
url	`hxxps[://]tac[.]vpnla[.]org:8443`	TAC Agent C2 endpoint; agent beacons about every 150 seconds.	REPORTED	2026-11-07	[S9]
user-agent	`TAC-Agent/1.0`	HTTP User-Agent of the TAC Agent implant.	REPORTED	2026-11-07	[S9]
sha256	`55e6384f6d1648be9b48fb899e46623e9c05eb0df2cbf95f6701680d4e7cbc2a`	tac_agent.py (TAC Agent 0.1.1) at /opt/py3/tac_agent.py on GreyNoise victim 1.	REPORTED	2026-11-07	[S9]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
sha256	`7cf69bd6573a90d7bd287810b5c3746841cee6a7f77cadd016f34a97fc7b2361`	OpenRC init script /etc/init.d/tac-agent (308 bytes) on GreyNoise victim 2.	REPORTED	2026-11-07	[S9]
sha256	`9f8db02efe7c1396c570c3828eea5149e752249972f9db317f3e32900c806dad`	/tmp/apk_repos, an attacker-written apk repository list pointing at alternative mirrors.	REPORTED	2026-11-07	[S9]
filepath	`/opt/py3/tac_agent.py`	Implant location; also seen at /usr/local/bin/tac_agent.py.	REPORTED	2026-11-07	[S9]
filepath	`/usr/local/bin/tac_agent.py`	Alternate implant location.	REPORTED	2026-11-07	[S9]
filepath	`/opt/py3/usr/bin/python3.12`	Bundled Python runtime dropped to run the implant on hosts without python3.	REPORTED	2026-11-07	[S9]
filepath	`/opt/py3/run_tac.sh`	Launcher script for the implant.	REPORTED	2026-11-07	[S9]
filepath	`/etc/init.d/tac-agent`	OpenRC service used for persistence (enabled with rc-update add tac-agent default).	REPORTED	2026-11-07	[S9]
filepath	`/root/.config/tac/agent.json`	Implant configuration; a .lock file sits beside it and /run/tac-agent.pid holds the PID.	REPORTED	2026-11-07	[S9]
filepath	`/run/tac-agent.pid`	Implant PID file.	REPORTED	2026-11-07	[S9]
filepath	`/tmp/py3.tar.gz`	Staged Python runtime archive; also /tmp/py3_min.tar.gz and split parts named /tmp/py3part.*.	REPORTED	2026-11-07	[S9]
filepath	`/tmp/tac-agent.init`	Staging copy of the init script.	REPORTED	2026-11-07	[S9]
filepath	`/tmp/apk_repos`	Attacker-written apk mirror list.	REPORTED	2026-11-07	[S9]
filepath	`/tmp/resolv.conf.bak`	Backup made before the attacker overwrote /etc/resolv.conf with nameserver 1.1.1.1.	REPORTED	2026-11-07	[S9]
filepath	`/tmp/wtest`	5 MB write-test file created with dd (also /tmp/zzz1 and /tmp/exec_test.txt as test artifacts); usually removed.	REPORTED	2026-11-08	[S9]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filepath	`/home/alpine/.ssh/authorized_keys`	Attacker keys appended here and to /root/.ssh/authorized_keys.	REPORTED	2026-11-07	[S9] [S5]
filepath	`/root/.ssh/authorized_keys`	Attacker keys appended for root after doas escalation.	REPORTED	2026-11-07	[S9]
other	`ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIC+fr+jwfsBA8u1VnsHZL4Tz5zujgovCL6JgYzUYkfvR SSHHOLE-HIT`	Attacker SSH public key (comment SSHHOLE-HIT) added to alpine and root authorized_keys.	REPORTED	2026-11-07	[S9]
other	`ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIFQrQmHWfW5QjOEZ4+Y5cz4yuF/dTlneMsoRlpe/jsTJ fleet-access`	Attacker SSH public key (comment fleet-access) added to authorized_keys.	REPORTED	2026-11-07	[S9]
other	`HASSH 6372ee6957562199b2fb773b0be1bf34`	SSH client fingerprint seen in confirmed exploitation sessions 2026-11-07 to 2026-11-10. May be shared with benign clients built on the same library.	REPORTED	2026-11-07	[S9]
other	`HASSH a2de0f306611e0957be704f5b0e35a82`	SSH client fingerprint seen in exploitation sessions 2026-11-07 to 2026-11-08.	REPORTED	2026-11-07	[S9]
other	`HASSH 38da7a9dfb196c72a7354bb4cdce64d9`	SSH client fingerprint seen in exploitation sessions on 2026-11-08.	REPORTED	2026-11-08	[S9]
command	`/opt/py3/usr/bin/python3.12 /opt/py3/tac_agent.py run -d`	Implant launch command.	REPORTED	2026-11-07	[S9]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
command	`/usr/sbin/sshd -p 2222 -o AllowTcpForwarding=yes`	Attacker started a second sshd on port 2222 with TCP forwarding enabled.	REPORTED	2026-11-07	[S9]
command	`echo "104.21.88.83 tac.vpnla.org" >> /etc/hosts`	Pins the C2 hostname in /etc/hosts.	REPORTED	2026-11-07	[S9]
command	`rc-update add tac-agent default`	Enables the implant service at boot.	REPORTED	2026-11-07	[S9]
command	`doas -n id`	Checks for passwordless root through doas immediately after login.	REPORTED	2026-11-07	[S9]
command	`grep -qF "SSHHOLE-HIT" /root/.ssh/authorized_keys`	Idempotence check before appending the attacker key.	REPORTED	2026-11-07	[S9]
command	`export HISTFILE=/dev/null`	Decoded start of a base64 command block that disables shell history before writing keys.	REPORTED	2026-11-08	[S9]
command	`id; uname; hostname`	Commands run through non-interactive SSH sessions after the Previdian honeypot login (reported as three separate commands).	REPORTED	2026-11-06	[S1] [S11]
port	`2222/tcp`	Listener of the attacker-started sshd.	REPORTED	2026-11-07	[S9]
port	`8443/tcp`	Outbound C2 port for TAC Agent.	REPORTED	2026-11-07	[S9]
url	`hxxp[://]169[.]254[.]169[.]254/latest/meta-data/`	Cloud instance metadata queried after login (also http://100.100.100.200/latest/meta-data/ for Alibaba Cloud). Benign address; the behavior from an SSH session is the indicator.	REPORTED	2026-11-07	[S9]
other	`Accepted password for alpine from`	sshd log string in /var/log/messages on Alpine. A password login for alpine, root or any key-only account whose shadow field is "*" indicates successful exploitation.	REPORTED		[S5] [S2]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`Accepted password for root from`	Derived from the Alpine guidance and the standard sshd log format: root has "*" on Alpine since about 3.16, so any password login for root on an affected host is suspect.	DERIVED		[S5]
other	`SSH password authentication attempt with a password of 257 to 1,024 bytes`	Derived exploit trait. Not visible on the wire because SSH is encrypted; observable only on honeypots or with sshd debug logging. Early attempts used passwords made entirely of the letter A.	DERIVED	2026-11-05	[S5] [S10]
ipv4	`152[.]233[.]50[.]185`	SANS ISC: source of long-password SSH attempts on honeypots (44; AS212238). Attempt only.	REPORTED		[S10]
ipv4	`92[.]255[.]57[.]7`	SANS ISC: long-password attempts (43; AS55286). Attempt only.	REPORTED		[S10]
ipv4	`195[.]178[.]110[.]78`	SANS ISC: long-password attempts (23; AS48090). Attempt only.	REPORTED		[S10]
ipv4	`109[.]94[.]173[.]13`	SANS ISC: long-password attempts (15; AS202660). Attempt only.	REPORTED		[S10]
ipv4	`87[.]241[.]132[.]12`	SANS ISC: long-password attempts (10; AS12297). Attempt only.	REPORTED		[S10]
ipv4	`52[.]119[.]124[.]122`	SANS ISC: long-password attempts (10; AS32329). Attempt only.	REPORTED		[S10]
ipv4	`185[.]2[.]148[.]137`	SANS ISC: long-password attempts (5; AS29119). Attempt only.	REPORTED		[S10]
ipv4	`220[.]77[.]237[.]35`	SANS ISC: long-password attempts (5; Korea Telecom AS4766). Attempt only.	REPORTED		[S10]
ipv4	`82[.]74[.]132[.]129`	SANS ISC: long-password attempts (5; AS33915). Attempt only.	REPORTED		[S10]
ipv4	`220[.]70[.]219[.]98`	SANS ISC: long-password attempts (4; AS4766). Attempt only.	REPORTED		[S10]
ipv4	`154[.]80[.]128[.]173`	SANS ISC: long-password attempts (4; AS215925). Attempt only.	REPORTED		[S10]
ipv4	`121[.]190[.]39[.]238`	SANS ISC: long-password attempts (4; AS4766). Attempt only.	REPORTED		[S10]
ipv4	`121[.]163[.]224[.]97`	SANS ISC: long-password attempts (3; AS4766). Attempt only.	REPORTED		[S10]
ipv4	`58[.]151[.]184[.]226`	SANS ISC: long-password attempts (3; AS3786). Attempt only.	REPORTED		[S10]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
ipv4	`62[.]210[.]173[.]100`	SANS ISC: long-password attempts (2; Scaleway AS12876). Attempt only.	REPORTED		[S10]
ipv4	`183[.]99[.]38[.]238`	SANS ISC: long-password attempts (2; AS4766). Attempt only.	REPORTED		[S10]
ipv4	`112[.]162[.]23[.]132`	SANS ISC: long-password attempts (2; AS4766). Attempt only.	REPORTED		[S10]
url	`hxxp[://]156[.]238[.]252[.]37:8000/bot[.]x86_64`	Botnet payload URL that SANS ISC found inside a password field sent by a buggy brute-force script (downloaded to /tmp/b). SANS judges this activity probably unrelated to the SSHole exploit itself, though such oversized passwords could trigger the bypass by accident.	REPORTED	2026-11-01	[S10]
filepath	`/tmp/b`	Drop path for the bot.x86_64 payload in the brute-force script noted by SANS ISC.	REPORTED	2026-11-01	[S10]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

The attacker connects to an exposed sshd on a musl-based, non-PAM Linux host and offers a password of 257 to 1,024 bytes for an account whose shadow field is "*", typically alpine or root. Since a 2016 change made to stop username enumeration, sshd hashes the supplied password even for accounts without a usable hash, borrowing a salt from another local account; musl's crypt() refuses SHA-256/512 inputs over 256 bytes and returns "*" rather than an error, which equals the stored "*" and is accepted as a match [S5] [S11] [S12]. One connection is enough. In the intrusions GreyNoise recorded, the attacker then profiled the host (id, uname, os-release, container and mount checks), used passwordless doas to become root, read /etc/shadow and existing SSH keys, queried cloud metadata endpoints, appended its own ed25519 keys to the alpine and root authorized_keys files with shell history disabled, and in some cases dropped a self-contained Python 3.12 runtime plus the TAC Agent implant, which beacons over HTTPS to a Cloudflare Worker, can run shell commands, move files and update itself, and persists as an OpenRC service. One intrusion also started a second sshd on port 2222 with TCP forwarding [S9].

Threat actor

Unattributed; one activity cluster tracked by GreyNoise as "GreyNoise Threat 10" (GT10) · also tracked as GT10

Attribution confidence: Low · **Motivation:** Unknown. Access building and persistence in the GT10 intrusions; watchTowr is reported to have seen only botnets and crypto miners. · **Suspected origin:** Unknown

GreyNoise states its clusters are automatically generated investigative leads, not attribution. Source addresses span cloud providers and carriers in several countries and say little about who is behind them. No government or vendor has named a threat group. Multiple unrelated actors are almost certainly involved.

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Reconnaissance	T1595.002 Active Scanning: Vulnerability Scanning	Mass scanning of TCP 22 followed by oversized-password attempts; SANS ISC saw long-password attempts jump from near zero to 713 on 2026-11-06, and GreyNoise tagged the first bypass attempts on 2026-11-05. [S9] [S10]	Perimeter and honeypot telemetry; sshd "Failed password" bursts for alpine and root from new sources.
Initial Access	T1190 Exploit Public-Facing Application	Single SSH password authentication with a 257 to 1,024 byte password against an account whose password field is "*" on a musl, non-PAM sshd (CVE-2026-123158). [S5] [S1] [S9]	"Accepted password for" in /var/log/messages for accounts that have no password (alpine, root, key-only users).
Initial Access	T1078.003 Valid Accounts: Local Accounts	The bypass yields a normal session as an existing local account (alpine, root), so later activity looks like a legitimate login. [S5] [S9]	Compare the authentication method in sshd logs with the account's expected method (publickey only).
Execution	T1059.004 Command and Scripting Interpreter: Unix Shell	Commands run through non-interactive SSH sessions, including sh -c chains and a base64-encoded command block. [S9] [S1]	Process auditing for sh spawned by sshd-session with long or encoded command lines.
Privilege Escalation	T1548.003 Abuse Elevation Control Mechanism: Sudo and Sudo Caching	Uses the passwordless doas rule of the alpine user on official cloud images (doas -n id, doas -n sh -c ...) to act as root; also reads /etc/doas.d/wheel.conf. [S9] [S5]	doas entries in /var/log/messages shortly after a password login for alpine.
Discovery	T1082 System Information Discovery	id, uname, hostname, /etc/os-release, process, network and mount listings. [S1] [S9] [S11]	Low value alone; correlate with a preceding anomalous password login.

Tactic	Technique	Procedure observed	Detection opportunity
Discovery	T1613 Container and Resource Discovery	Checks for /var/run/docker.sock, cgroups, capabilities and /proc/1/exe to learn whether the host is a container. [S9]	Access to docker.sock by non-service accounts.
Credential Access	T1003.008 OS Credential Dumping: /etc/passwd and /etc/shadow	Reads /etc/shadow through doas. [S9]	File-access auditing on /etc/shadow; doas log lines containing shadow.
Credential Access	T1552.005 Unsecured Credentials: Cloud Instance Metadata API	Requests to 169.254.169.254 and 100.100.100.200 metadata endpoints from the compromised session. [S9]	Enforce IMDSv2 and alert on metadata requests from shell tools such as wget or curl; review cloud audit logs for use of instance-role credentials from new addresses.
Credential Access	T1552.004 Unsecured Credentials: Private Keys	Reads root's SSH key material through doas. [S9]	File-access auditing on /root/.ssh.
Persistence	T1098.004 Account Manipulation: SSH Authorized Keys	Appends ed25519 keys with comments SSHHOLE-HIT and fleet-access to /home/alpine/.ssh/authorized_keys and /root/.ssh/authorized_keys; in one case deletes existing key lines first. [S9]	File-integrity monitoring on authorized_keys; search all hosts for the two key strings or comments.
Persistence	T1037.004 Boot or Logon Initialization Scripts: RC Scripts	Installs /etc/init.d/tac-agent and enables it with rc-update add tac-agent default. [S9]	New files in /etc/init.d and new entries under /etc/runlevels/default.
Defense Evasion	T1562.003 Impair Defenses: Impair Command History Logging	Sets HISTFILE=/dev/null before writing keys. [S9]	Process command lines or environment containing HISTFILE=/dev/null.

Tactic	Technique	Procedure observed	Detection opportunity
Command and Control	T1105 Ingress Tool Transfer	Uploads a Python 3.12 runtime archive (in split parts) and tac_agent.py to /tmp and /opt/py3; rewrites resolv.conf and apk mirrors and tests outbound connectivity first. [S9]	New directories under /opt and archives in /tmp written by sshd child processes; unexpected changes to /etc/resolv.conf, /etc/hosts and /etc/apk/repositories.
Command and Control	T1071.001 Application Layer Protocol: Web Protocols	TAC Agent beacons over HTTPS to tac.vpnla.org on port 8443 about every 150 seconds with User-Agent TAC-Agent/1.0; the host is fronted by Cloudflare. [S9]	DNS and TLS SNI matches for tac.vpnla.org; periodic outbound 8443 from servers; /etc/hosts entries for the name (which bypass DNS logging).
Command and Control	T1090 Proxy	Starts a second sshd on port 2222 with AllowTcpForwarding=yes, which would let the host relay traffic. The purpose is inferred from the options; GreyNoise does not state it. [S9]	Unexpected listeners on 2222; sshd processes with -p or -o arguments not started by the init system.
Exfiltration	T1041 Exfiltration Over C2 Channel	The implant supports file upload and download through its C2 channel. This is a described capability; observed data theft is not reported. [S9]	Outbound volume to the C2 host.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

SSH password login accepted for an account that should be key-only (Alpine/musl) `SIGMA`

```
title: SSH Password Login For Password-Disabled Account (CVE-2026-123158)
status: experimental
logsource:
  product: linux
  service: sshd
detection:
  selection:
    message|contains:
      - 'Accepted password for alpine from'
      - 'Accepted password for root from'
  condition: selection
falsepositives:
  - Hosts where alpine or root have been given a real password on purpose
level: high
```

On Alpine the sshd lines are in /var/log/messages. Extend the user list with your own key-only and directory-service accounts. Any hit on a host where the account's shadow field is "*" should be handled as a compromise.

Password logins by user on musl hosts, with first-seen source `SPLUNK SPL`

```
index=linux (sourcetype=syslog OR source="/var/log/messages") "sshd" "Accepted password for"
| rex "Accepted password for (?<user>\S+) from (?<src_ip>\S+) port (?<src_port>\d+)"
| search user IN ("alpine","root")
| stats earliest(_time) as first_seen latest(_time) as last_seen count by host user src_ip
| convert ctime(first_seen) ctime(last_seen)
| sort first_seen
```

Run from 2026-11-05 onward (earlier if logs allow; the flaw has existed since 2016). Compare src_ip with the indicator list, but do not rely on IP matches.

TAC Agent implant and attacker sshd on Linux `SIGMA`

```
title: TAC Agent Implant Or Secondary sshd After SSHole Exploitation
status: experimental
logsource:
  product: linux
  category: process_creation
detection:
  sel_agent:
    CommandLine|contains:
      - 'tac_agent.py'
      - 'rc-update add tac-agent'
      - 'tac.vpnla.org'
      - 'SSHHOLE-HIT'
  sel_sshd:
    Image|endswith: '/sshd'
    CommandLine|contains|all:
      - '-p 2222'
      - 'AllowTcpForwarding=yes'
  sel_hist:
    CommandLine|contains: 'HISTFILE=/dev/null'
  condition: sel_agent or sel_sshd or sel_hist
falsepositives:
  - Administrators who legitimately disable history or run sshd on 2222
level: high
```

Needs process command-line telemetry (auditd, eBPF agent or EDR). Many Alpine hosts have none; fall back to file checks for /etc/init.d/tac-agent, /opt/py3 and the two attacker keys.

TAC Agent command-and-control lookups and TLS `SURICATA`

```
alert dns $HOME_NET any -> any any (msg:"HUNT TAC Agent C2 DNS query tac.vpnla.org (SSHole post-exploitation)"; dns.query;
content:"tac.vpnla.org"; nocase; endswith; classtype:trojan-activity; sid:9026111; rev:1;)
alert tls $HOME_NET any -> $EXTERNAL_NET any (msg:"HUNT TAC Agent C2 TLS SNI tac.vpnla.org"; tls.sni; content:"tac.vpnla.org"; nocase;
endswith; classtype:trojan-activity; sid:9026112; rev:1;)
alert http $HOME_NET any -> $EXTERNAL_NET any (msg:"HUNT TAC-Agent User-Agent"; http.user_agent; content:"TAC-Agent/"; startswith;
classtype:trojan-activity; sid:9026113; rev:1;)
```

The attacker pins the hostname in /etc/hosts, so the DNS rule can miss; the SNI rule still applies. The User-Agent rule only fires where TLS is inspected.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
OpenSSH portable (sshd) on Linux with musl libc and PAM not in use	All versions before 10.6p2 when password authentication is enabled, an account has "*" as its password field, and another local account has a 5 or 6 hash	10.6p2	CVE-2026-123158	8.1 (CVSS 3.1, AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H)	0.01014 (63rd percentile) as of 2026-11-09	Yes (added 2026-11-09)	2026-11-12
Alpine Linux openssh package (openssh-server, or openssh-server-pam with UsePAM no)	3.16 through 3.24 and edge	edge 10.6_p2-r0; 3.24 10.3_p1-r2; 3.23 10.2_p1-r1; 3.22 10.0_p1-r11; 3.21 9.9_p2-r1; 3.20 9.7_p1-r6; 3.19 9.6_p1-r3; 3.18 9.3_p2-r4; 3.17 9.1_p1-r7; 3.16 9.0_p1-r6	CVE-2026-123158	8.1	0.01014 as of 2026-11-09	Yes (added 2026-11-09)	2026-11-12
Official Alpine cloud images (tiny-cloud qcow2, VHD, AMI) with default alpine user and passwordless doas	3.18.11 through 3.24.3, once any 6 hash exists on the instance; cloud-init images are not exposed because password authentication is off	Images built from 3.21.10, 3.22.8, 3.23.8, 3.24.4 or later; running instances must be patched individually	CVE-2026-123158	8.1	0.01014 as of 2026-11-09	Yes (added 2026-11-09)	2026-11-12

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Other musl-based systems running OpenSSH (OpenWrt, Buildroot, Yocto builds; container images that run sshd)	Named as affected platforms in reporting; exposure depends on the build using OpenSSH without PAM and on the account conditions above. No vendor-specific version lists found.	OpenSSH 10.6p2 or a vendor backport; check with the device or image vendor	CVE-2026-123158	8.1	0.01014 as of 2026-11-09	Yes (added 2026-11-09)	2026-11-12

Immediate (0–24 hours)

- Inventory every host, VM, container and appliance that runs sshd on a musl-based system (Alpine first; then OpenWrt, Buildroot and Yocto devices and any container image that starts sshd). Flag those reachable from the internet or from untrusted networks. `IT OPS` [S5] [S2] [S3]
- On Alpine run apk upgrade -U -a, then rc-service sshd restart. Confirm the installed openssh package matches the fixed version for the branch. The upgrade alone does not replace the running daemon. `IT OPS` [S5]
- Where patching cannot happen today, set PasswordAuthentication no (drop-in file in /etc/ssh/sshd_config.d on 3.19 and later, and in sshd_config itself on older releases), run sshd -t, restart sshd and verify with sshd -T | grep -i passwordauthentication. Keep an existing session open and test key login first. `IT OPS` [S5] [S3]
- On every exposed musl host search /var/log/messages (and any forwarded copies) for "Accepted password for" naming alpine, root or key-only accounts, from 2026-11-05 onward at minimum. `SOC` [S5] [S2]
- Check authorized_keys for all users, especially alpine and root, for keys with the comments SSHHOLE-HIT or fleet-access or any key you cannot account for. Check for /etc/init.d/tac-agent, /opt/py3, /usr/local/bin/tac_agent.py, an sshd listening on 2222, and a tac.vpnla.org line in /etc/hosts. `SOC` [S9]
- Block and alert on tac.vpnla.org at DNS and web proxy layers. Add the confirmed attacker addresses to short-lived blocklists; do not block the shared Cloudflare address. `SOC` [S9]
- If a successful bypass login cannot be ruled out, isolate the host and treat it as compromised: rebuild from a fixed image and rotate every secret that was on it (SSH keys, local password hashes, API tokens, deployment credentials, and cloud instance-role credentials). `SOC` [S5] [S9] [S1]

Short term (1–7 days)

- Replace Alpine cloud images and golden templates with builds from 3.21.10, 3.22.8, 3.23.8, 3.24.4 or later; rebuild container images that include openssh-server and redeploy. `IT OPS` [S5]

- Ask vendors of network, IoT, OT and storage devices built on OpenWrt, Buildroot or Yocto whether their firmware uses OpenSSH without PAM and when a fix will ship. Restrict management SSH on those devices to an admin network until answered. `IT OPS` [S2] [S3] [S8]
- Run the hunting queries in this report across centralized logs and extend the look-back as far as retention allows; review doas use, recently created users and recently changed files on exposed hosts. `SOC` [S5] [S9]
- Review cloud audit logs for use of instance-role credentials from unfamiliar addresses for any Alpine instance that was exposed; attackers queried metadata endpoints after login. `SOC` [S9]
- Report status against the CISA KEV due date of 2026-11-12 where federal or contract obligations apply, and record exceptions with compensating controls. `LEADERSHIP` [S8]
- Move Alpine 3.21 and older systems onto a supported branch; 3.21 left support on 2026-11-01 and older branches received this fix only as an exception. `IT OPS` [S5]

Long term

- Make key-only SSH the enforced baseline (PasswordAuthentication no, KbdInteractiveAuthentication no) in all images and configuration management, and test for drift. `IT OPS` [S5] [S3]
- Remove sshd from container images; use the orchestrator's exec or a bastion instead. `IT OPS` [S5] [S11]
- Stop exposing SSH directly to the internet; require VPN, a bastion with MFA or zero-trust access, and limit source addresses. `IT OPS` [S3] [S13]
- Forward auth and process logs from Alpine and appliance hosts to central logging and deploy file-integrity monitoring on authorized_keys, /etc/init.d, /etc/hosts and /etc/shadow. `SOC` [S9]
- Plan for same-day patching of internet-facing services: this flaw went from fix to public exploit in about four hours and to exploitation attempts the same day. Fund asset inventory that records libc and distribution, not only package names. `LEADERSHIP` [S9] [S3] [S11]
- Remove passwordless doas or sudo from default cloud accounts where operations allow, so that a single account compromise is not root. `IT OPS` [S5] [S9]

Workarounds & compensating controls

- Set PasswordAuthentication no and restart sshd; this fully removes the attack path on unpatched hosts. `IT OPS` [S5] [S3]
- Use openssh-server-pam with UsePAM yes where password logins are required; PAM-checked setups are not affected. `IT OPS` [S5]
- Restrict TCP 22 with security groups or firewall rules to known management addresses; disable SSH entirely on affected systems that do not need it. `IT OPS` [S11] [S13]
- Keep PermitRootLogin at its default (prohibit-password) so root is not directly reachable; note this does not protect the alpine user or other doas-capable accounts. `IT OPS` [S5]
- Enforce IMDSv2 with a hop limit of 1 on cloud instances to make metadata credential theft harder after a host compromise. This is a general

hardening step derived from the observed metadata queries, not vendor guidance for this CVE. `IT OPS` [S9]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] The Hacker News: Hackers Target OpenSSH SSHole Flaw Within Hours of Disclosure, Gain Root on Honeypot
Published 2026-11-06 · `B1` Usually reliable, confirmed by other sources
Briefing source; updated 2026-11-08 with Previdian's revised counts (20 attempts, 13 addresses). Relays Previdian's claims, now corroborated by GreyNoise.

[S2] BleepingComputer: OpenSSH flaw lets attackers log into password-disabled Linux accounts
Published 2026-11-05 · `B1` Usually reliable, confirmed by other sources
Briefing source; disclosure-day coverage of the root cause and checks.

[S3] SecurityWeek: OpenSSH Rushes Patches for 'SSHole' Authentication Bypass
Published 2026-11-06 · `B1` Usually reliable, confirmed by other sources
Briefing source; maintainer and researcher statements.

[S4] SecurityWeek: Hackers Exploiting 'SSHole' Authentication Bypass in OpenSSH
Published 2026-11-09 · `B2` Usually reliable, probably true
Follow-up; relays watchTowr's statement that only botnets and crypto miners had exploited the flaw, plus Previdian, GreyNoise and Defused observations. watchTowr's original post was not located.

[S5] Alpine Linux: openssh-server password authentication bypass (security advisory)
Published 2026-11-05 · `A1` Completely reliable, confirmed by other sources
Primary vendor advisory: exact conditions, fixed package versions, workaround commands, detection guidance.

[S6] OpenSSH: OpenSSH release notes (10.6p2)
Published 2026-11-05 · `A1` Completely reliable, confirmed by other sources
Primary upstream source for the fix and credit.

[S7] CVE Program (MITRE): CVE-2026-123158 record
Published 2026-11-05 · `A1` Completely reliable, confirmed by other sources
CVSS 8.1, CWE-394; CISA enrichment marks exploitation as active. Last updated 2026-11-10. Description gives the password range as 256 to 1,024 characters; other primary sources say 257.

[S8] CISA: Known Exploited Vulnerabilities Catalog (entry for CVE-2026-123158)
Published 2026-11-09 · `A1` Completely reliable, confirmed by other sources
Added 2026-11-09, due 2026-11-12; ransomware use Unknown. Catalog version 2026.11.09.

[S9] GreyNoise: CVE-2026-123158 (SSHole) event page
Published 2026-11-10 · `A2` Completely reliable, probably true
Original sensor telemetry and the main source of indicators; last updated 2026-11-10 12:10 UTC. Clusters are investigative leads, not attribution. Long page read in two parts; some tables were not fully captured.

[S10] SANS Internet Storm Center: Scans for Sshole Vulnerability (CVE-2026-123158)
Published 2026-11-08 · `A2` Completely reliable, probably true
Honeypot counts and source addresses for long-password attempts; honeypots record only the first 255 characters.

[S11] Help Net Security: OpenSSH flaw exploited in the wild just hours after disclosure (CVE-2026-123158)
Published 2026-11-06 · `B2` Usually reliable, probably true
Detail on Previdian's observations and the root cause; notes that public proof-of-concept repositories are unverified.

[S12] Özgün Kültekin (Wakefield): SSHole researcher write-up
Published 2026-11-05 · `A1` Completely reliable, confirmed by other sources
Original researcher's explanation and history of the bug. Only the write-up was read; linked code was not fetched.

[S13] eSentire: OpenSSH SSHole Authentication Bypass Vulnerability (CVE-2026-123158)
Published 2026-11-09 · `B2` Usually reliable, probably true
Vendor advisory summarizing others' findings; no original indicators.

[S14] FIRST: EPSS score for CVE-2026-123158
Published 2026-11-09 · `A2` Completely reliable, probably true
EPSS 0.01014, percentile 0.63482. The model lags confirmed exploitation; do not use it to lower priority.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2012-08-29	musl adds SHA-256/512 crypt with a 256-byte key limit; its crypt() already returned "*" rather than NULL on failure.	[S12]
2016-07-01	OpenSSH change for CVE-2016-6210 (username enumeration) makes sshd hash passwords for accounts without a usable hash, creating the conditions for the bypass (month per researcher; day not given).	[S12] [S2]
2026-11-04	OpenSSH maintainers learn of the issue; fix committed at 21:18 UTC.	[S3] [S9]
2026-11-05	OpenSSH 10.6p2 released (09:01 UTC); researcher write-up published (12:19 UTC); first public exploit on GitHub (13:16 UTC); CVE-2026-123158 reserved and published (15:46 UTC); Alpine advisory and fixed packages for 3.16 through edge; first GreyNoise-tagged bypass attempt (18:34 UTC).	[S6] [S9] [S7] [S5]
2026-11-06	Previdian reports first attempt within nine hours of CVE publication and a confirmed root login on an Alpine honeypot from 89.116.89[.]18; SANS ISC honeypots record a peak of 713 long-password attempts.	[S1] [S11] [S10]
2026-11-07	GreyNoise observes its first successful exploitation (00:46 UTC); TAC Agent implant deployed on a sensor host (13:46 UTC) and an OpenRC persistence service on a second (20:37 UTC).	[S9]

Date	Event	Source
2026-11-08	Previdian total reaches 20 attempts from 13 addresses in nine countries; SANS ISC publishes its diary; watchTowr reported to have seen exploitation by botnets and miners over the weekend.	[S1] [S10] [S4]
2026-11-09	CISA adds CVE-2026-123158 to the KEV catalog with a due date of 2026-11-12.	[S8] [S7]
2026-11-10	GreyNoise reports 20 confirmed post-exploitation chains from six attacker addresses, with activity from 79.116.138[.]30 continuing that morning.	[S9]

Relevance to Indianapolis, Indiana & managed clients

Most servers run by Indianapolis and Indiana organizations use glibc distributions with PAM and are not exposed, so this is a targeted clean-up rather than a fleet-wide emergency. The risk sits in places that are often missing from asset inventories. Alpine is the most common base for container images, and development teams at software firms, universities and health systems sometimes add sshd to containers or run small Alpine virtual machines in AWS and Azure as jump hosts, build runners or lab systems; the official cloud images give the default alpine user passwordless root. State and local government agencies, K-12 districts and universities (large research networks in particular) tend to have unmanaged Linux instances exposed on port 22. Indiana's manufacturing and logistics sector, along with utilities and healthcare device fleets, uses embedded gateways, industrial routers and IoT devices built on OpenWrt, Buildroot or Yocto; most ship Dropbear, which is not affected, but some ship full OpenSSH, and owners depend on vendor firmware to fix it. Small and mid-size businesses rarely run Alpine deliberately but may have it inside appliances or hosted workloads set up by a developer or contractor. For managed IT service clients the practical work is: scan client environments and cloud accounts for musl-based sshd, close or restrict internet-facing port 22, apply the fix or the PasswordAuthentication workaround, and run the log and authorized_keys checks before declaring a host clean. Organizations with federal contracts or grant conditions that reference the KEV catalog should note the 2026-11-12 due date. No Indiana victim has been reported.

Intelligence gaps

- No count of internet-facing hosts that meet all the exploitation conditions; the 22 million SSH hosts cited from Shodan is the total SSH population, not the vulnerable one.
- No confirmed production victim has been named; all confirmed compromises so far are honeypots or sensors.
- The operator of the TAC Agent cluster (GT10) is unknown, and no other vendor has analyzed the implant. Its enrollment token and full capabilities are only partly published.
- watchTowr's botnet and crypto-miner observations are known only through secondary reporting; no miner or botnet family names, hashes or pools were found.
- Previdian's full list of 13 attacker addresses was not found in the sources opened; only one address is published in press coverage.

- No vendor-specific advisories were found for OpenWrt, Buildroot or Yocto based products; which commercial devices are affected is unknown.
- Sources differ on the lower bound of the password length (CVE record: 256; Alpine and researcher: 257) and on whether a second account must have a 5 or 6 hash (required per Alpine; the researcher's summary says only that a fresh system with no passwords set is unaffected).
- KEV lists ransomware use as Unknown; watch for ransomware or extortion actors adopting the bypass and for any CISA or vendor alerts with further indicators.
- SANS ISC promised a follow-up on how many honeypot logins succeeded; not yet published as of 2026-11-10.

Other notes

- This report updates the earlier intelligence report CTI-20261106-02 (2026-11-06). Main changes: KEV listing confirmed (added 2026-11-09, due 2026-11-12); the single-source Previdian address is now corroborated by GreyNoise; a much larger indicator set and the first implant (TAC Agent) are documented.
- The briefing rated this item High; CVSS remains 8.1 because of high attack complexity (specific configuration needed). Where the conditions are met the attack is trivial and gives root on Alpine cloud images, so affected hosts should be handled as critical.
- The three-day KEV due date is shorter than the historical three-week norm; the entry cites BOD 26-04 and forensic triage requirements. Federal civilian agencies are bound by it; others should treat it as a strong priority signal.
- OpenSSH's maintainers describe the root cause as outside sshd (in how musl's crypt() signals failure) but fixed it in sshd. Systems with other software that compares crypt() output to a stored "*" on musl may have similar problems; the researcher notes a 2024 musl mailing-list thread about a similar BusyBox failure.
- Public proof-of-concept repositories exist. Previdian warns they are unverified and may contain malware; none were fetched for this report. Use the Alpine advisory's configuration checks for validation rather than running public exploit code.
- SANS ISC observed that some long passwords predate the disclosure (23 on 2026-11-01) and come from buggy brute-force scripts that paste shell commands into the password field. Such scripts could trigger the bypass by accident, so a successful login is not proof of a deliberate SSHole exploit, but it is equally a compromise.
- GreyNoise also publishes JA4T TCP fingerprints, about 30 hashes of a victim's .ash_history, hashes of modified /etc/hosts and resolv.conf files, 579 Paramiko-tagged scanner addresses and one partly redacted 103.x address; these were left out as low-value or incomplete.
- Maintainer Damien Miller said the fix was released within about a day of the report because AI-assisted tools rediscover bugs quickly, making long embargoes risky; the researcher used AI agents to run about 17,600 authentication tests. Expect short or no advance notice for similar flaws.
- EPSS (about 1 percent) is far below what confirmed exploitation warrants; prioritize on the KEV listing and sensor evidence.

CTI-20261110-03 v1.0 · Generated 2026-11-10 07:37 EST from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:AMBER Restricted to the recipient's organization and its trusted clients/contractors on a need-to-know basis.